

Kobayashi Maru — Build, Attack/ Observe

Énoncé de l'exercice — promotion Master 1, 2026

DOCUMENT
Énoncé

PROMOTION
Master 1



Sommaire

Énoncé de l'exercice — promotion Master 1, 2026	3
1. Introduction	3
Déroulé général	3
2. Informations initiales	3
3. Le cadre de l'exercice	4
Le catalogue est public, votre cahier des charges ne l'est pas	4
4. Phase 1 — Conception de votre infrastructure vulnérable	5
4.1 Horaires	5
4.2 Conception	5
4.3 Documentation	5
4.4 Livrables Phase 1	6
5. Phase 2 — Découverte, attaque et observation	6
5.1 Horaires	6
5.2 Étapes à réaliser	6
5.3 Livrables Phase 2	6
6. Évaluation	7
6.1 Structure du fichier CSV attendu	7
6.2 Contraintes	7
6.3 Objectif	7
6.4 Critères d'évaluation	7
7. Guide pratique — <i>Check ta vuln</i>	8
7.1 Méthodologie rapide	8
7.2 Vérifier un accès au système de fichiers	8
7.3 Emplacements conseillés pour les flags	8
7.4 Implémenter des règles de détection dans EveBox	8
7.5 Alias de feignants	9
8. Règles de conduite	9

Énoncé de l'exercice — promotion Master 1, 2026

Vous ne concevez pas votre infrastructure de zéro. Un catalogue de profils d'entreprise est remis à toute la promotion ; chaque groupe en choisit un, reçoit le cahier des charges correspondant et le réalise à la lettre, comme une prestation d'intégration.

1. Introduction

Cet exercice évalue votre capacité d'adaptation dans un temps contraint, à travers une simulation pratique « **Build, Attack/Observe** » sur plusieurs jours.

■ Déroulé général

- **Phase 1** : conception et déploiement de votre infrastructure vulnérable
- **Phase 2** : attaque et observation

Vous jouerez successivement trois rôles :

1. **Builder** — vous êtes l'intégrateur d'une entreprise fictive. Vous choisissez un cahier des charges dans le catalogue : il décrit l'organisation, ses métiers, ses contraintes et la liste des services attendus. Vous livrez un SI conforme et documenté, dans lequel **vous** décidez où placer les faiblesses.
2. **Attaquant** — vous auditez le SI d'un autre groupe à partir d'une documentation partielle, le « Document Attaquant ».
3. **Observateur / défenseur** — vous détectez et documentez les attaques menées contre *votre* SI à l'aide de la sonde Suricata fournie.

2. Informations initiales

Les groupes sont constitués **aléatoirement** par l'équipe pédagogique. Groupes de **6 étudiants**.

Chaque groupe dispose :

- d'une **configuration WireGuard (via LabAuto)** donnant accès à un environnement contenant :
 - une **jumpbox**,
 - une **sonde Suricata** avec l'interface **EveBox**,
 - un **routeur OPNsense**,
 - un **hôte Linux avec Docker** installé ;
- d'un **fichier CSV contenant la liste des flags**, transmis par l'équipe pédagogique ;
- du **Catalogue des profils d'infrastructure** : le groupe y choisit un profil et le déclare à l'équipe pédagogique avant la fin de la première demi-journée, qui lui remet en retour le **cahier des charges complet** correspondant.

Chaque groupe est responsable de la mise en place d'un **système d'information (SI)** et de ses services **via Docker Compose** sur l'hôte fourni.

Le SI doit rester **accessible** durant toute la durée de l'exercice, aux horaires prévus.

Appariements : chaque groupe joue le rôle de **builder** pour un autre groupe, et le rôle d'**attaquant** sur un autre groupe.

Les services vulnérables doivent être choisis dans le dépôt **Vulhub**. L'accès externe au SI passe par l'**OPNsense** fourni. L'installation et l'utilisation de **SysReptor** sont conseillées pour rédiger les rapports de la phase 2 en parallèle du pentest.

Une **notice** vous sera fournie pour vous accompagner dans la réalisation des étapes obligatoires : déploiement des services, routage et filtrage, détection via Suricata, publication des services vulnérables.

3. Le cadre de l'exercice

Vous êtes intégrateur : le besoin vous est donné, la façon de le rendre vulnérable vous appartient. Le cadre est le même pour tous les groupes, quel que soit le profil choisi.

Élément	Règle
Infrastructure à construire	un profil choisi dans le catalogue , réalisé conformément à son cahier des charges
Nombre de services	la tranche ferme du cahier des charges (16 ou 17 selon le profil), tous obligatoires
Vulnérabilités	12 services vulnérables , choisis librement dans Vulhub
Points d'entrée	exactement 3 services de niveau 1 , et ce sont les seuls exploitables depuis l'extérieur
Profondeur	2 chaînes complètes N1 → N2 → N3
Réalisme	noté : données métier, comptes, bannières, noms d'hôtes

Le catalogue est public, votre cahier des charges ne l'est pas

Toute la promotion reçoit le **catalogue des profils** : sept entreprises fictives décrites en quelques lignes, de quoi choisir un terrain. Personne ne reçoit le catalogue *complet* des cahiers des charges.

Le **cahier des charges** de votre profil — la liste exacte des services, les zones, les jeux de données, les comptes attendus — n'est remis qu'à votre groupe. Il ne se diffuse pas : le communiquer à un autre groupe revient à lui donner la carte de votre SI.

Vous ne saurez donc pas quel profil votre cible a construit, et elle ne saura pas quel profil vous avez construit. L'équipe pédagogique veille par ailleurs à ce qu'un groupe et le groupe qu'il attaque ne construisent jamais le même profil.

Et même à profil identique, deux SI restent différents : le choix des images, des versions, des données métier et surtout **le placement des vulnérabilités, des chaînes et des flags** appartient à chaque groupe, et reste secret jusqu'à la remise du document pédagogique.

Le **chef de groupe** est celui dont l'adresse apparaît, dans le document de *Constitution des groupes*, sur la ligne comportant un nombre dans la colonne « attaquant ». C'est lui qui envoie les livrables ; le groupe attaquera le groupe indiqué par cette colonne.

4. Phase 1 — Conception de votre infrastructure vulnérable

4.1 Horaires

```
- Jour 1 13h00 - 18h00
- Jour 2 09h30 - 18h00
- Jour 3 09h30 - 11h30
```

4.2 Conception

Pendant la durée impartie, vous devez :

1. Réceptionner le document de **Constitution des groupes** et le **CSV des flags**.
2. **Choisir un profil** dans le *Catalogue des profils*, le déclarer à l'équipe pédagogique et récupérer le cahier des charges complet correspondant. Lire ce cahier des charges, le *Socle technique* (environnement fourni, segmentation, publication, niveaux, flags) et le *Guide builder* (méthode de mise en vulnérabilité, chaînes, détection).
3. **Répartir les tâches** entre les 6 membres et tenir un tableau « qui a fait quoi » (service, vulnérabilité, chapitre de documentation, règle de détection) — c'est la base de la notation individuelle.
4. **Déployer tous les services de la tranche ferme** de votre CDC via Docker Compose, en respectant le réseau et le niveau d'exposition indiqués.
5. **Choisir vous-mêmes** quels services porteront une vulnérabilité, et lesquelles, en piochant dans Vulhub (*annexe 1 — Catalogue Vulhub*). Quotas imposés à tous les groupes : **12 services vulnérables** (2 × 6 membres), dont **3 de niveau N1**. Ces 3 N1 sont **obligatoirement les points d'entrée du SI** : ce sont les seules vulnérabilités atteignables avec les accès initiaux, et tout le reste du SI ne doit être atteignable qu'en passant par l'un d'eux. Les **9 services vulnérables restants se répartissent librement entre N2 et N3**.
6. **Adapter** les fichiers `docker-compose.yml` et `Dockerfile` fournis par Vulhub afin de rendre l'exercice plus réaliste, car certaines vulnérabilités sont trop brutes pour être exploitables. **Il est interdit de rendre inexploitable la vulnérabilité choisie**.
7. Construire **au moins 2 chaînes complètes N1 → N2 → N3** : l'accès à un niveau est conditionné par l'exploitation réussie du précédent. Méthode : *Guide builder*.
 - Il est possible d'aller plus en profondeur, **mais attention au temps imparti**.
 - **Tous les services de niveau 1 doivent être accessibles via l'accès initial**, sinon ils sont dépendants d'un autre et donc instanciés plus profondément dans votre SI.
 - Vous devez avoir **exactement 3 points d'entrée N1**, ni plus ni moins : aucune autre vulnérabilité ne doit être exploitable directement depuis l'extérieur.
8. **Placer les flags** du CSV aux emplacements prévus, un flag par étape exploitable.
9. Configurer le **routage et le filtrage sur l'OPNsense**, et la **publication** des services exposés.
10. Vérifier **vous-mêmes** chaque exploit avant la livraison (*annexe 2 — Grille de recette*).

4.3 Documentation

- Documenter **qui a mis en place quel service / vulnérabilité / chapitre** de la documentation, pour la notation individuelle.
- Documenter, dans le document pour la pédagogie, **quel flag est associé à quel service** ainsi que les modifications apportées aux conteneurs.
- Fournir les **accès initiaux aux services** dans vos documentations.
- Réaliser un **schéma réseau complet** du SI simulé (conteneurs, réseaux Docker, OPNsense, sonde) qui sera intégré dans la doc pédago.

- Réaliser un **schéma réseau partiel** du SI simulé qui sera intégré dans la doc attaquant.

En cas de questionnement, demandez à l'équipe pédagogique.

4.4 Livrables Phase 1

- [PDF] **Document Pédagogique** : documentation complète de l'infrastructure.
- [PDF] **Document Attaquant** : schéma réseau minimal + accès initiaux.

Intitulé du mail : [2026] Kobayashi Maru Phase 1 - Groupe #X → assistants@ecole2600.com, envoyé par le chef de groupe, avec les 2 PDF en pièces jointes.

Les intitulés doivent être respectés **à la lettre**, sans quoi le mail peut être ignoré. Si l'équipe pédagogique demande une variante, elle la communiquera : ne l'inventez pas.

5. Phase 2 — Découverte, attaque et observation

5.1 Horaires

- Jour 3 13h00 - 18h00
- Jour 4 09h30 - 18h00

5.2 Étapes à réaliser

- Réception du **Document Attaquant** de l'équipe pédagogique (schéma réseau + accès initiaux).
- Séparation du groupe en 2 : **attaquants** et **défenseurs**.

Attaquants

- Préparation des scénarios d'attaque et repérage des vulnérabilités exploitables.
- Exploitation des vulnérabilités découvertes.
- Rédaction du rapport d'attaque avec preuves, flags trouvés **et heure de l'exploitation réussie**.
- On doit identifier qui a rédigé quel chapitre du rapport, pour la notation individuelle.
- Soyez courts et factuels : c'est un rapport technique, non managérial.

Défenseurs (préparable pendant la phase de build)

- Préparation des **règles de détection** des attaques potentielles dans Suricata.
- Indiquer dans le rapport **les prompts utilisés pour la génération des règles** ainsi que les règles produites.
- Collecte des logs des services vulnérables et des preuves d'intrusion.
- Rédaction d'un rapport de détection expliquant les règles produites et les attaques détectées.
- On doit identifier qui a rédigé quel chapitre du rapport et quelle règle.
- Soyez courts et factuels.
- Remplir la **Feuille d'évaluation** du groupe builder.

5.3 Livrables Phase 2

- [PDF] **Rapport de pentest** : préciser, pour chaque flag trouvé, qui dans le groupe a réalisé l'attaque.
- [PDF] **Rapport de détection** : préciser qui a rédigé quelle règle et réalisé quelle capture de log.
- [Google Form] **Feuille d'évaluation du groupe builder** : évaluer le SI découvert.

- [CSV] Évaluation individuelle des membres du groupe.

Intitulés des mails :

- [2026] Kobayashi Maru Phase 2 - Groupe #X — rapports, envoyé par le chef de groupe.
- [2026] Kobayashi Maru Phase 2 - Note de <email 2600> — CSV, envoyé individuellement par chaque étudiant.

6. Évaluation

6.1 Structure du fichier CSV attendu

```
email,type,note
prenom.nom1@ecole2600.com,GRP,20
prenom.nom2@ecole2600.com,GRP,17
prenom.nom3@ecole2600.com,GRP,16
autresprenom.nom1@ecole2600.com,AIDE,17
autresprenom.nom2@ecole2600.com,AIDE,10
```

La colonne **type** identifie le type de membre évalué :

- **GRP** → membres de votre propre groupe
- **AIDE** → membres d'un autre groupe qui vous auront aidé

6.2 Contraintes

- Vous devez évaluer **l'intégralité des membres de votre groupe**.
- Vous pouvez évaluer des membres d'un autre groupe qui vous auront aidé, **sauf** ceux appartenant aux groupes où vous êtes **builder** ou **attaquant**.

6.3 Objectif

L'évaluation par les pairs vise à valoriser la motivation individuelle, encourager l'entraide entre groupes, tout en maintenant des règles claires d'équité.

6.4 Critères d'évaluation

Note individuelle : 20 points

Points	Critère
4	Évaluation par les pairs
8	Partie technique « builder » — dont conformité au cahier des charges
8	Partie technique « attaquant » ou « défenseur »

Malus builder : service de la tranche ferme manquant, vulnérabilité rendue inexploitable, flag introuvable ou mal placé, SI indisponible pendant les horaires, document attaquant révélant plus que le minimum.

7. Guide pratique — *Check ta vuln*

7.1 Méthodologie rapide

1. Cloner le dépôt Vulhub du service ciblé :

```
git clone https://github.com/vulhub/vulhub
cd vulhub/<chemin>
docker compose up -d
```

2. Analyser le `docker-compose.yml` et le `Dockerfile` (image, ports, volumes).
3. Identifier la vulnérabilité (nom, CVE, type : RCE, SQLi, LFI, etc.).
4. Tester localement (nmap, nikto, curl, sqlmap, metasploit, scripts fournis).
5. Vérifier si l'exploitation donne :
 - un shell (accès FS complet),
 - une lecture de fichiers via LFI / dir traversal,
 - un accès à la base de données (SQLi),
 - une divulgation de configuration ou de credentials.
6. Placer le flag dans l'emplacement approprié.
7. Documenter, pour la pédagogie, chaque service : vecteur d'attaque, exploit possible, emplacement du flag, preuve attendue.

7.2 Vérifier un accès au système de fichiers

- **RCE / command injection** : exécuter `cat /etc/passwd` ou écrire `echo FLAG{...} > /root/flag.txt`.
- **Reverse shell** : vérifier avec `ls /`, `ls /root`, `ls /var/www`.
- **LFI / traversal** : tester `?file=../../../../etc/passwd`.
- **SQLi** : utiliser `SELECT ... INTO OUTFILE` si possible, ou stocker le flag en base.
- **Auth bypass / creds par défaut** : uploader un webshell si possible.
- **FTP / SMB ouverts** : déposer directement le flag dans le partage.

Toujours valider l'exploit vous-même pour confirmer l'accès et la difficulté.

7.3 Emplacements conseillés pour les flags

Type d'exploitation	Emplacement
RCE / shell	<code>/root/flag.txt</code> ou <code>/flag.txt</code>
LFI / RFI	<code>/var/www/html/flag.txt</code> ou <code>/etc/flag</code>
SQLi	table <code>flags</code> , colonne <code>flag_string</code>
FTP / SMB	<code>/srv/ftp/flag.txt</code>
Web app sans accès FS	flag en base ou dans un profil utilisateur
Windows (RCE / SMB)	<code>C:\flag.txt</code> ou <code>%SYSTEMROOT%\temp\flag.txt</code>

7.4 Implémenter des règles de détection dans EveBox

Les règles déjà présentes se trouvent dans :

- `/var/lib/suricata/rules/suricata.rules` — règles ET/Open, téléchargées au build ;

- `/etc/suricata/rules/tp-local.rules` — règles du TP, sid 9000001+.

Vos règles vont dans `tp-local.rules`, avec des `sid` à partir de 9000001. La documentation de Suricata : RTFM.

7.5 Alias de feignants

```
alias ssh_tunnel='ssh -N -L 8443:192.168.10.1:443 -L 5636:192.168.10.30:5636 -L 5001:192.168.10.50:5001 etudiant@10.85.4.20'
alias ssh_jump='ssh etudiant@10.85.4.20'
alias ssh_suricata='ssh -J etudiant@10.85.4.20 etudiant@192.168.10.30'
alias ssh_vulhub='ssh -J etudiant@10.85.4.20 etudiant@192.168.10.50'

export OPN='https://127.0.0.1:8443'
export EVE='https://127.0.0.1:5636'
export HUB='https://127.0.0.1:5001'
```

8. Règles de conduite

- Le SI doit rester **accessible pendant toute la durée de l'exercice**, aux horaires prévus. Une panne = un service à réparer, pas un service à supprimer.
- **Interdit** : attaquer un autre groupe que celui qui vous est assigné, attaquer l'infrastructure de l'école ou LabAuto, les attaques par déni de service, la destruction de données chez le builder.
- Un attaquant qui casse un service prévient immédiatement le builder et l'équipe pédagogique.
- En cas de doute sur le CDC : demandez à l'équipe pédagogique. Un CDC ambigu s'interprète comme un vrai cahier des charges — vous posez la question au « client ».